UNIVERSITY OF LONDON

BSc EXAMINATION 2023

For Internal Students of
Royal Holloway

DO NOT TURN OVER UNTIL TOLD TO BEGIN

IY3501/IY3501R: Security Management

for FIRST SIT/RESIT CANDIDATES

Time Allowed: **TWO hours**

Answer **THREE** questions.
No credit will be given for attempting any further questions.

Important Copyright Notice
This exam paper has been made available in electronic form
strictly for the educational benefit of current Royal Holloway students
on the course of study in question.
No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

©Royal Holloway, University of London 2023

Question 1. There are two main approaches to defining information security in the context of security management: the threat-based approach and the objective-based approach.

(a) Briefly describe, with reference to **ONE** example, what is meant by the term threat-based approach. [3 marks]

(b) Briefly describe, providing **ONE** example for each case, the **THREE** main security violations that are generally considered under the threat-based approach. [9 marks]

(c) Define the following terms:

(i) Vulnerability [2 marks]

(ii) Attacker [2 marks]

(d) Consider a fashion retailer that conducts business online.

(i) Describe **TWO** possible vulnerabilities that may affect this business. In your answer, explain their potential impact on achieving the business goals, if they were exploited. [10 marks]

(ii) For **EACH** vulnerability discussed in part (i), describe a possible attacker that may exploit the vulnerability, making reference to the attacker's motivations and capability. [8 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 2. (a) Give a definition of risk in the context of information security management. [2 marks]

(b) Explain what is meant by a qualitative risk evaluation, and give an advantage and a disadvantage of this approach as compared with a quantitative approach. [6 marks]

(c) A control is a measure to modify risk.

(i) Give **ONE** example of a control that increases risk. In your answer, explain the purpose of the control and how it may damage security. [4 marks]

(ii) Give **TWO** examples of controls that someone may implement on their personal laptop. For each example, justify why this control is useful. [6 marks]

(d) ISO/IEC 27002 is a security management standard relating to controls.

(i) Summarise the scope of this standard. [3 marks]

(ii) Explain the role of the Statement of Applicability in relation to the ISO/IEC 27000 series of standards. [3 marks]

(e) A security policy is an example of a security control. Imagine you are the CISO of an IT company. Outline the components of a suitable removable media management policy for the organisation. [10 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 3. (a) Define the following terms:

(i) Information security event [2 marks]

(ii) Information security incident [2 marks]

(b) Imagine you are responsible for incident management in a large IT company. An employee reports to you that their computer is running slowly.

(i) Is this an example of an information security event, an information security incident, or neither of these? Justify your answer. [2 marks]

(ii) Outline the next steps you would take in response to this report. [6 marks]

(c) Explain **THREE** ways that an organisation can improve its information security management system using knowledge gained from analysing and resolving security incidents. [12 marks]

(d) Business continuity and disaster recovery plans can help mitigate the effects of major incidents.

(i) Define the term business continuity. [2 marks]

(ii) Describe **TWO** differences between business continuity and disaster recovery. [4 marks]

(iii) Identify **ONE** organisation and describe **ONE** example of an issue that should be addressed in business continuity planning for this organisation. In your answer, justify why this issue is of importance to the organisation. [4 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 4. (a) Identify the main steps in the risk management process. [6 marks]

(b) Describe **THREE** ways in which legal and regulatory compliance can be introduced within the risk management process. [12 marks]

(c) The following security breach has been widely reported:

In 2020, Ticketmaster UK was fined over one million pounds for failing to keep its customers' personal data secure. The fine was issued by the Information Commissioner's Office (ICO) following a cyber-attack on the Ticketmaster website in 2018.

The ICO said personal information and payment details had potentially been stolen from more than nine million customers in Europe. An investigation found a vulnerability in a third-party chatbot built by Inbenta Technologies, which Ticketmaster had installed on its online payments page. A cyber-attacker was able to use the chatbot to access customer payment details.

Following the breach, 60,000 Barclays bank customers were victims of fraud. The ICO said Monzo, the Commonwealth Bank of Australia, Barclaycard, Mastercard and American Express had all warned Ticketmaster of suspected fraud. But Ticketmaster took nine weeks to start monitoring activity on its payments page, according to the ICO.

Source: `https://www.bbc.co.uk/news/technology-54931873`.

(i) Explain how this security breach can be seen as a breach of GDPR. [6 marks]

(ii) Explain **TWO** possible areas of weakness in the Ticketmaster risk management process that this breach may highlight. [10 marks]

END

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.